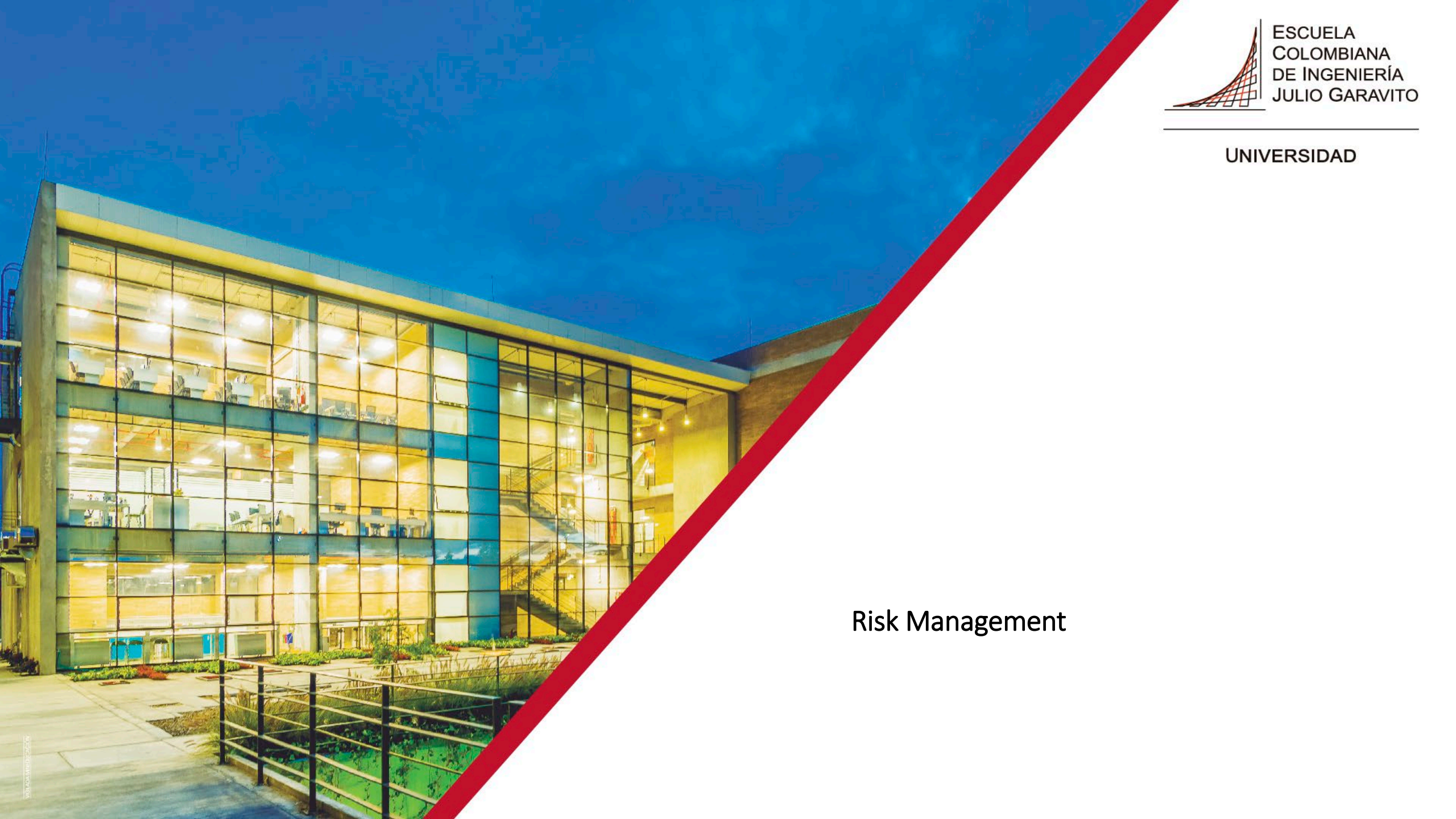




Risk Management

AGENDA

1. ¿Qué es la gestión de riesgos?
2. Marcos para la gestión de riesgos
3. Evaluación de los riesgos de seguridad de la información
4. Mecanismos de tratamiento de riesgos
5. Monitoreo y revisión de riesgos

AGENDA

1. **Introducción**
2. Establecimiento del contexto
3. Evaluación de los riesgos de seguridad de la información
4. Mecanismos de tratamiento de riesgos
5. Monitoreo y revisión de riesgos

INTRODUCCIÓN

The practice of protecting information by mitigating information risks. (*Wikipedia*)

The preservation of confidentiality, integrity and availability of information. (*ISO/IEC 27000:2018*)

INTRODUCCIÓN



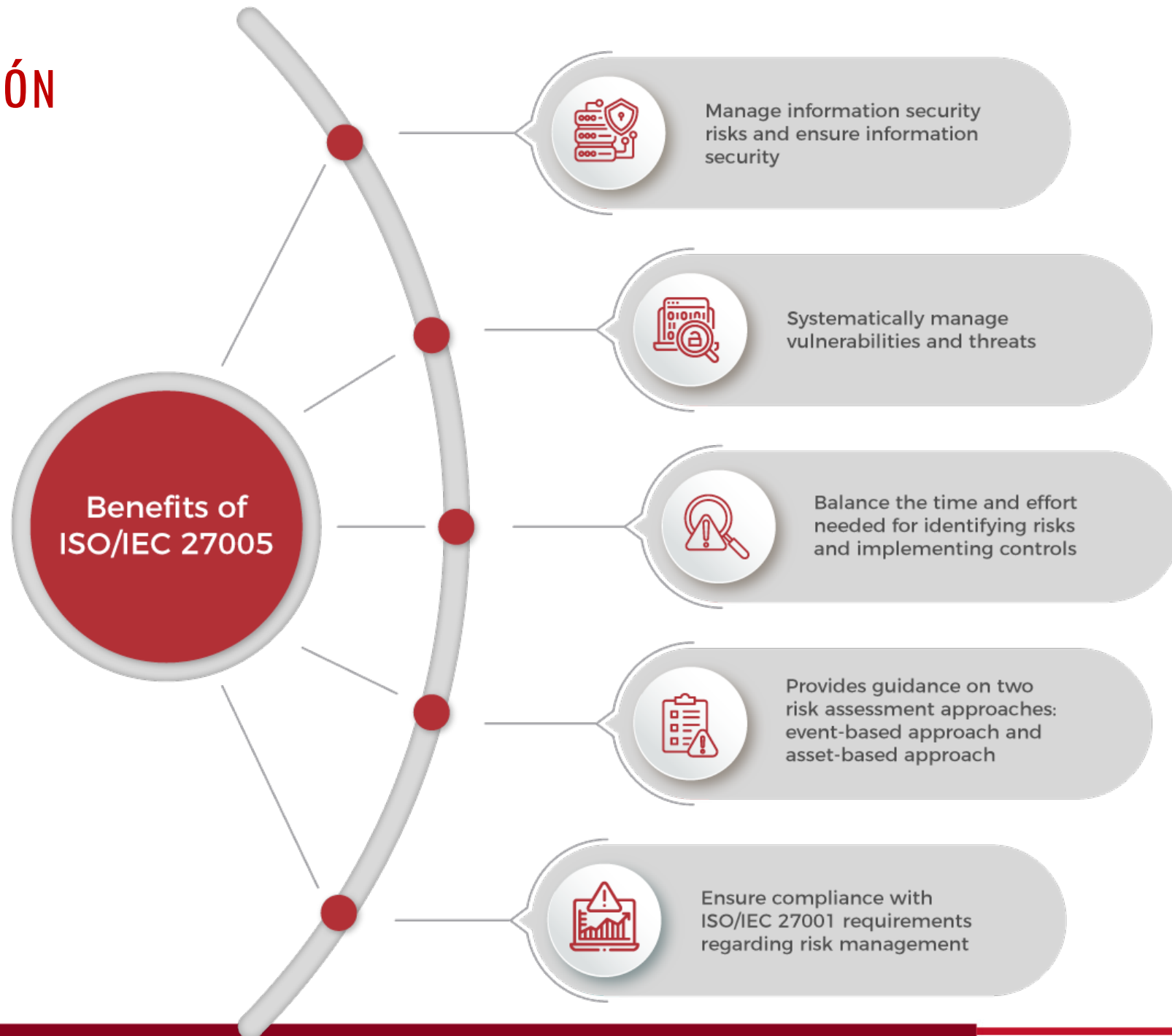
MAGERIT v.3 : Metodología de Análisis y
Gestión de Riesgos de los Sistemas de
Información



INTRODUCCIÓN

Process Description		
OCTAVE Allegro	ISO 27005	NIST
Eight steps: 1. Establish risk measurement criteria 2. Develop information asset profile 3. Identify information asset containers 4. Identify areas of concern 5. Identify scenarios 6. Identify risks 7. Analyze risks 8. Select Mitigation approach	Six main steps: 1. Context establishment 2. Risk assessment (identification, analysis, evaluation) 3. Risk treatment (modification, retention, avoidance, sharing) 4. Risk Acceptance 5. Risk communication and consultation 6. Information security risk monitoring and review	Four main steps: 1. Prepare for assessment 2. Conduct Assessment (identify threat sources and events; identify vulnerabilities; determine the likelihood of occurrence; determine the magnitude of impact determine risk) 3. Communicate results 4. Maintain Assessment

INTRODUCCIÓN



SEGURIDAD DE LA INFORMACIÓN

- Confidentiality
- Integrity
- Availability
- Non-repudiation



ISMS (Information Security Management System) - ISO/IEC 27001

Policies, procedures, plans, activities, controls, responsibilities, resources that are managed by an organization in order to protect its assets.

Risk management is the core element of an ISMS.



FAMILIA ISO/IEC 27000

ISO/IEC 27000

Overview and vocabulary

ISO/IEC 27001

Requirements for an ISMS

ISO/IEC 27005

Guidelines for information security risk management

ISO/IEC 27002

Guidance for information security controls

ISO/IEC 27007

Guidelines for auditing an ISMS

ISO/IEC 27003

Guidance for implementing an ISMS

ISO/IEC 27005:2018

Guidelines (*not requirements*) for information security risk management.

Applicable to any organization (regardless of sector) that implements an ISMS.

First edition of ISO/IEC 27005 was published in 2008, the second in 2011 and the third in 2018.

ISO 31000 –Guidelines for risk management.

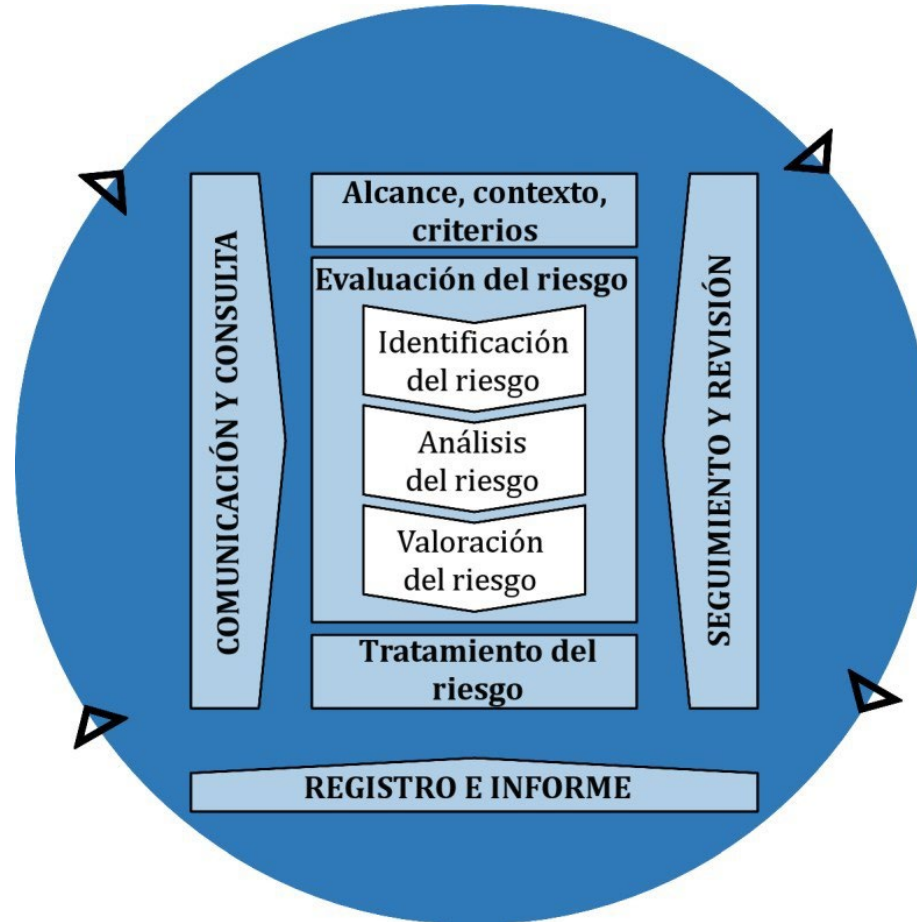
Risk (generally)

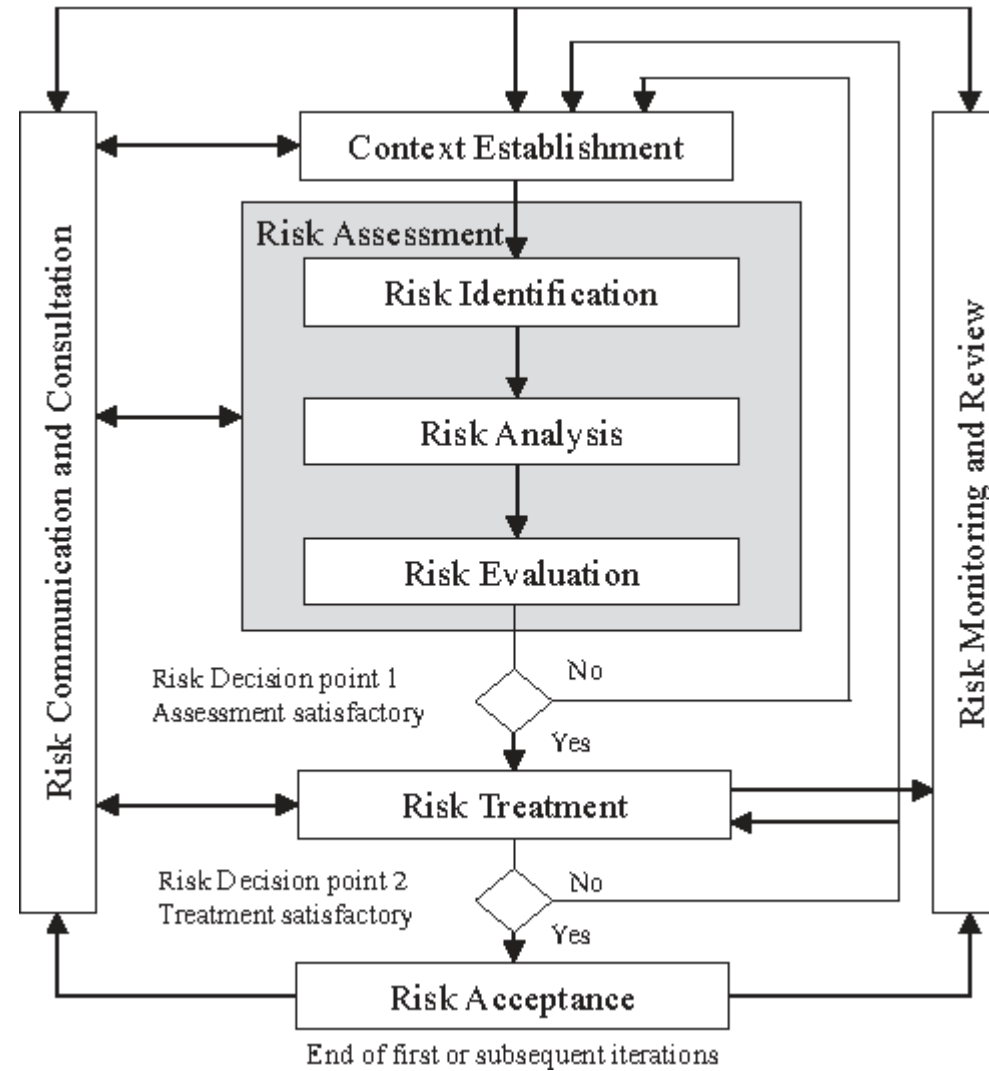
The effect of uncertainty on objectives

Risk (in the context of information security)

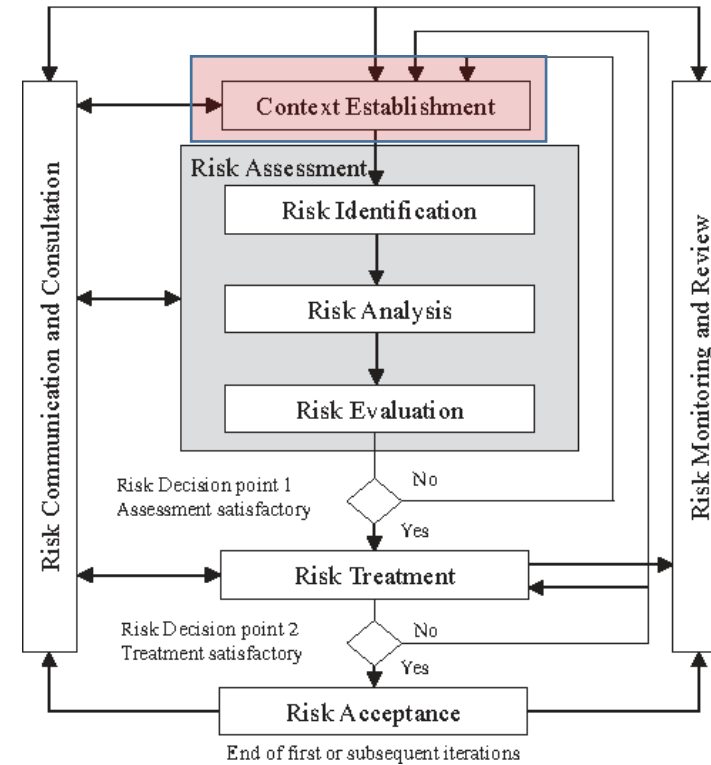
The possibility that threats will exploit vulnerabilities and cause harm

ISO/IEC 31000



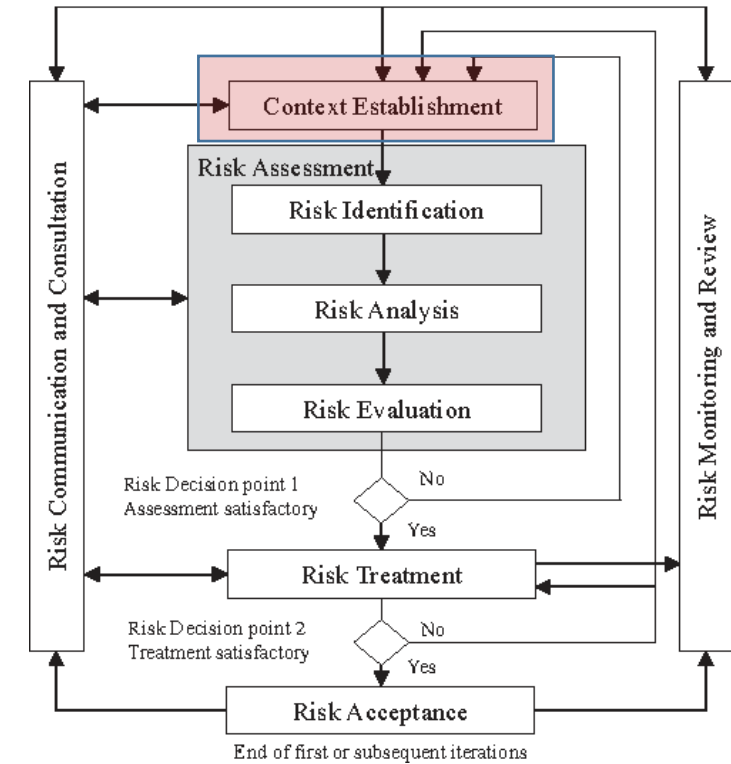


CONTEXT ESTABLISHMENT

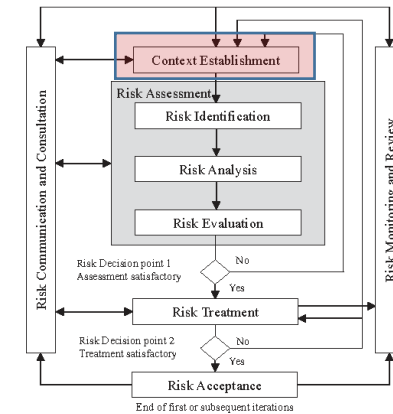


CONTEXT ESTABLISHMENT

- Understand the organization
- Define the purpose of risk management
- Define the scope and boundaries of the risk management process
- Consider the constraints



CONTEXT ESTABLISHMENT



Understand the organization

- Purpose
- Business
- Mission
- Values

Purpose of risk management

- Why a risk management process is necessary?

Scope and boundaries

- What is covered by the risk management process.

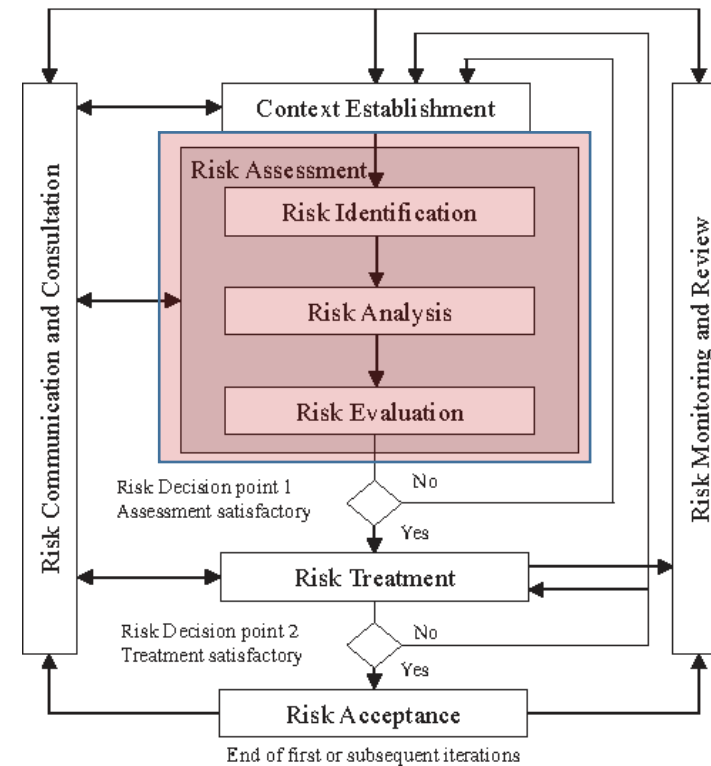
Constraints

- Originating from inside or
- from outside the
- organization.

RISK ASSESSMENT

- *Risk identification*
- *Risk analysis*
- *Risk evaluation*

Risk –combination of consequences and probability

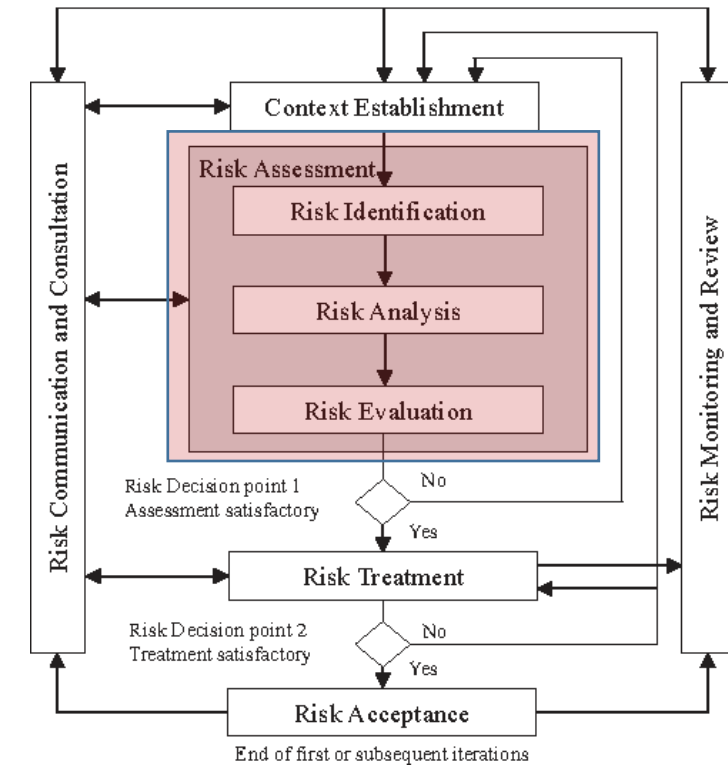


RISK ASSESSMENT

1. Identification of assets

Asset

“Anything that has value to an organization and which, therefore, requires protection.” *ISO/IEC 27005:2018*



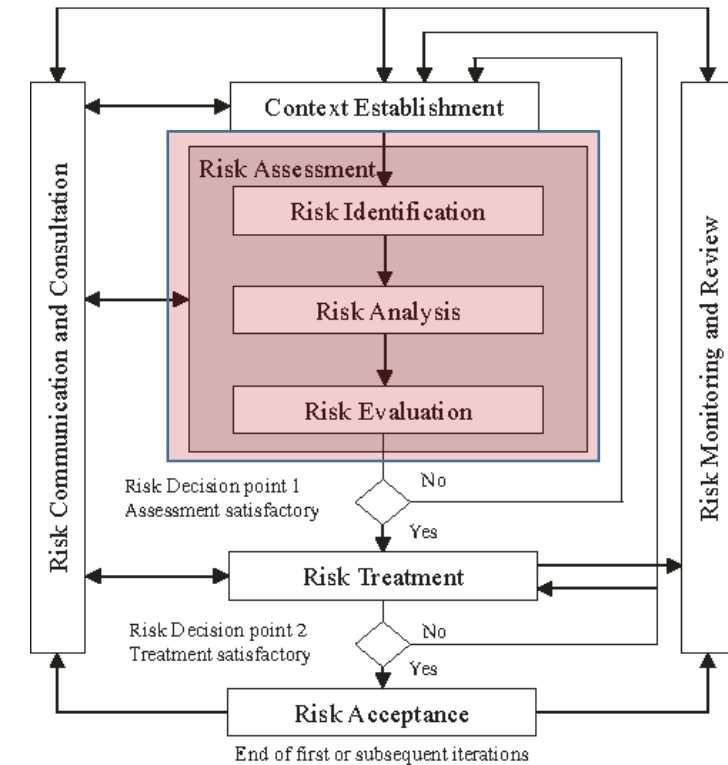
RISK ASSESSMENT - IDENTIFICATION OF ASSETS

Primary assets

- Business processes and activities (*not all processes*)
- Information (*not all information*)

Supporting assets

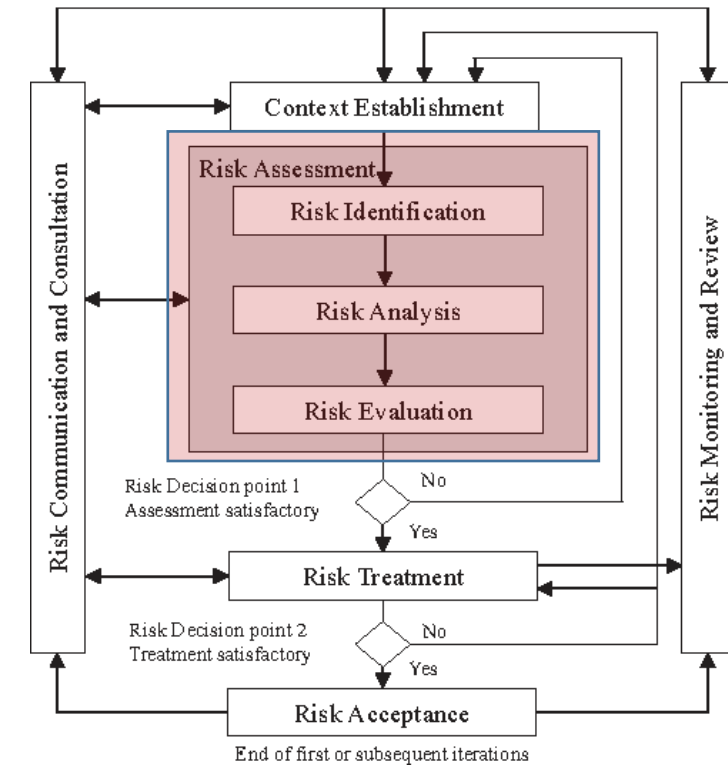
- Hardware
- Software
- Network
- Personnel
- Site (locations)
- Organization's structure



RISK ASSESSMENT — IDENTIFICATION OF THREATS

Threat—the potential cause of an unwanted incident, which can result in harm to a system or to an organization

ISO/IEC 27000:2018



RISK ASSESSMENT – IDENTIFICATION OF THREATS

Type	Examples of threats	Source
Physical damage	Destruction of equipment or media	A,D,E
	Dust, corrosion or freezing	A,D,E
	Fire	A,D,E
	Water damage	A,D,E
Natural events	Earthquake	E
	Volcanic phenomenon	E
	Flood	E
Loss of essential services	Loss of power supply	A,D,E
	Failure of telecommunication equipment	A,D
	Failure of utility systems (e.g., air conditioning)	A,D
Disturbance due to radiation	Electromagnetic radiation	A,D,E
	Electromagnetic pulses	A,D,E
Compromise of information	Theft of media or documents	D
	Data from untrustworthy sources	A,D
	Tampering with hardware	D
	Theft of equipment	D
	Remote spying	D
	Eavesdropping	D
Technical failures	Equipment failure	A
	Equipment malfunction	A
	Software malfunction	A
Unauthorized actions	Unauthorized use of equipment	D
	Fraudulent copying of software	D
	Use of counterfeit software	A,D
	Corruption of data	D
	Illegal processing of data	D
Compromise of functions	Denial of actions	D
	Abuse of rights	A,D
	Error in use	A

RISK ASSESSMENT – IDENTIFICATION OF THREATS

Origin of threat	Motivation	Possible consequences
Hacker, cracker	Challenge, ego, rebellion, status, monetary gain	Hacking Social engineering System intrusion, break-ins Unauthorized system access
Computer criminal	Monetary gain, unauthorized data alteration, illegal information disclosure, destruction of information	Spoofing System intrusion Fraudulent act (e.g. impersonation, interception)
Terrorist	Blackmail, destruction, exploitation, revenge, media coverage, political gain	Information warfare Bomb System attack (e.g. DDOS) System tampering
Industrial espionage	Economic advantage, economic espionage	Information theft Social engineering System penetration Unauthorized system access
Insiders (e.g. poorly trained, disgruntled, malicious, negligent, dishonest or terminated employees)	Curiosity, ego, revenge, monetary gain, unintentional errors, omissions	Computer abuse Blackmail Fraud and theft Input of falsified or corrupted data Malicious code Unauthorized system access Sale of personal information System bugs

RISK ASSESSMENT – IDENTIFICATION OF THREATS

Origin of threat	Motivation	Possible consequences
Hacker, cracker	Challenge, ego, rebellion, status, monetary gain	Hacking Social engineering System intrusion, break-ins Unauthorized system access
Computer criminal	Monetary gain, unauthorized data alteration, illegal information disclosure, destruction of information	Spoofing System intrusion Fraudulent act (e.g. impersonation, interception)
Terrorist	Blackmail, destruction, exploitation, revenge, media coverage, political gain	Information warfare Bomb System attack (e.g. DDOS) System tampering
Industrial espionage	Economic advantage, economic espionage	Information theft Social engineering System penetration Unauthorized system access
Insiders (e.g. poorly trained, disgruntled, malicious, negligent, dishonest or terminated employees)	Curiosity, ego, revenge, monetary gain, unintentional errors, omissions	Computer abuse Blackmail Fraud and theft Input of falsified or corrupted data Malicious code Unauthorized system access Sale of personal information System bugs

RISK ASSESSMENT — IDENTIFICATION OF VULNERABILITIES

Vulnerability—weakness of an asset or control that can be exploited by one or more threats.

ISO/IEC 27000:2018

RISK ASSESSMENT – IDENTIFICATION OF VULNERABILITIES

Types	Examples of vulnerabilities	Examples of threats
Hardware	Unprotected storage	Theft of media or documents
	Lack of care at disposal	Theft of media or documents
	Susceptibility to voltage variations	Loss of power supply
	Sensitivity to electromagnetic radiation	Electromagnetic radiation
	Insufficient maintenance/ faulty installation of storage media	Breach of information system maintainability
Software	No or insufficient software testing	Abuse of rights
	Lack of audit trail	Abuse of rights
	Known software issues (flaws)	Abuse of rights
	Wrong allocation of access rights	Abuse of rights
	Complicated user interface	Error in use
	Lack of identification and authentication mechanisms	Forging of rights
	Poor password management	Forging of rights
	Immature of new software	Software malfunction
	Incomplete or unclear specifications for developers	Software malfunction
	Lack of back-up copies	Tampering with software
Network	Unprotected communication lines	Eavesdropping
	Poor joint cabling	Failure of telecommunications equipment
	Insecure network architecture	Remote spying
	Transfer of passwords in clear	Remote spying
	Unprotected public network connections	Unauthorized use of equipment
	Inadequate network management (resilience of routing)	Saturation of the information systems
Personnel	Absence of personnel	Lack of availability
	Inadequate recruitment procedures	Errors
	Lack of security awareness	Errors, facilitating unauthorized access
	Lack of monitoring mechanisms	Illegal data processing
	Lack of policies for the acceptable use of assets	Unauthorized use of equipment. Malware.
Site	Inadequate (or lack of) physical security	Theft, destruction
	Unstable power grid	Loss of power supply
	Location in an area susceptible to flood	Flood
Organization	Lack of formal procedures for user registration and de-registration	Abuse of rights
	Insufficient provisions in contracts with customers and/ or third parties	Abuse of rights
	Lack of email policies	Errors in use
	Lack of information classification procedures	Errors in use

RISK ASSESSMENT — RISK ANALYSIS

	Quantitative	Qualitative
Objective	• Number of cyber security incidents by year, by type. • Amount of data stolen in a cyber attack. • Number of phishing emails received by an organisation in a year.	• Cyber security incident reports. • Agreed minutes of risk management meetings. • An organisation's published cyber security strategy.
Subjective	• An expert's estimation of the probability of a given type of cyber attack happening to an organisation, in a given year. • Traditional security culture survey data (for example: <i>how do you rate your organisation's security from 1 to 10?</i>).	• A description of a threat's capability. • Staff interviews. • Casual conversations with staff.

RISK ASSESSMENT – QUALITATIVE RISK ANALYSIS

- Uses qualifying attributes for consequences and likelihood
- Easy to understand
- Subjective

Likelihood	Frequent (5)	Medium (5)	Major (10)	Major (15)	Severe (20)	Severe (25)
	Likely (4)	Medium (4)	Medium (8)	Major (12)	Major (16)	Severe (20)
	Possible (3)	Medium (3)	Medium (6)	Medium (9)	Major (12)	Major (15)
	Unlikely (2)	Minor (2)	Medium (4)	Medium (6)	Medium (8)	Major (10)
	Rare (1)	Minor (1)	Minor (2)	Minor (3)	Medium (4)	Medium (5)
		Very low (1)	Low (2)	Medium (3)	High (4)	Very high (5)
	Consequences					

RISK ASSESSMENT – QUANTITATIVE RISK ANALYSIS

- Relies on numbers
- Uses historical data (e.g. incident data)
- More precise

Likelihood (incident history of the last 5 years)		Consequences Financial impact	
> 6 times	0.9	More than 100.000 \$	0.9
4-6 times	0.6	50.000\$ – 100.000 \$	0.6
1-3 times	0.4	10.000\$ – 50.000 \$	0.4
< 1 times	0.1	< 10.000\$	0.1

RISK ASSESSMENT — RISK EVALUATION

Determine the level of risk

Compare the level of risk with the risk criteria

Description of the threat	Likelihood (L)	Consequences (C)	Risk (LxC)	Ranking
DDOS attack	0.4	0.6	0.24	1
Fire in data center	0.1	0.9	0.09	5
X-employee disclosing confidential information	0.4	0.4	0.16	4
Power outage	0.9	0.1	0.09	6
Ransomware attack	0.4	0.4	0.16	3
Disclosure of passwords	0.6	0.4	0.24	2
Bomb threat	0.1	0.4	0.04	7

- **Mitigate:** Apply an additional control to reduce the Residual Risk.
- **Accept:** Accept the risk because the Residual Risk is under the Acceptable Risk Threshold, or because the cost of implementing the control is more expensive than the asset value.
- **Avoid:** Eliminate the origin of the Risk (for example replace the asset for a new one with the vulnerability and in this way, eliminate the origin of the risk).
- **Transfer:** Pass the Residual Risk to a third party (for example an insurance company).

RISK ASSESSMENT — RISK TREATMENT PLAN

- The risks assessed
- The selected treatment option(s)
- The control(s) for each risk
- Priorities
- Timeframes
- Responsibilities

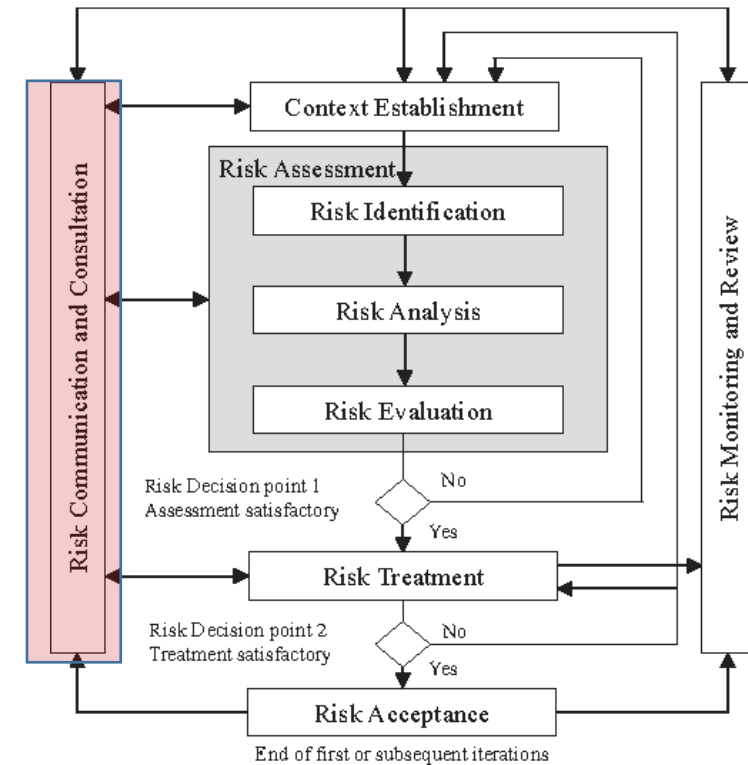
RISK ASSESSMENT — RISK TREATMENT PLAN

The risk that remains after treatment.

Risk	Likelihood (L)	Consequences (C)	Risk (LxC)	Ranking	Acceptable? Yes/ No	Treatment	Likelihood (L)	Consequences (C)	Residual risk	Acceptable? Yes/ No
DDOS attack	0.4	0.6	0.24	1	No	DDOS protection and mitigation service	0.4	0.1	0.04	Yes

RISK COMMUNICATION AND CONSULTATION

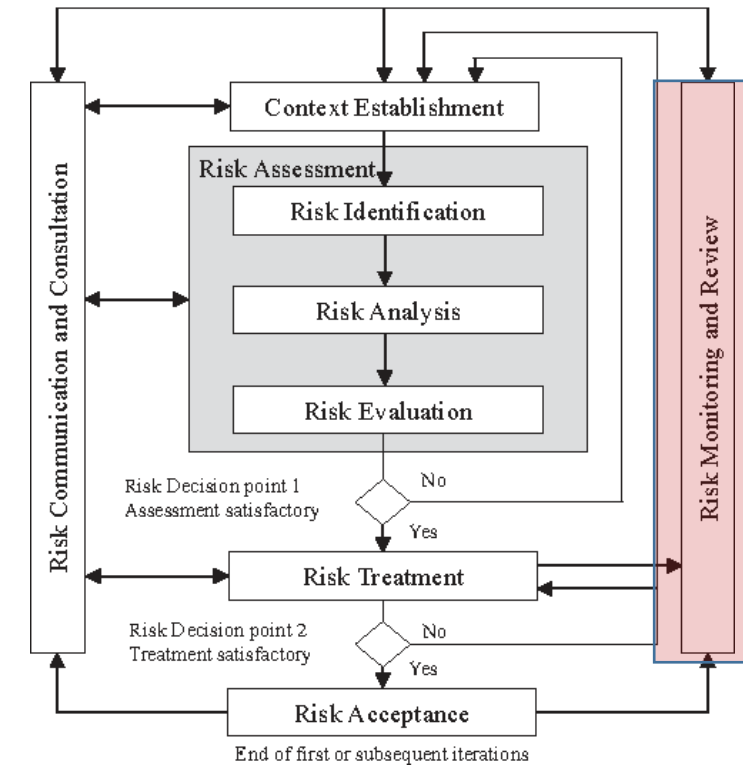
The stakeholders and the decision-makers should exchange information about risk management.



MONITORING AND REVIEW OF RISK FACTORS

Monitoring of risks and risk factors:

- new assets included in the risk management scope;
- modification of asset values;
- new threats;
- new or increased vulnerabilities;
- Information security incidents.



Gracias